# ChainGuard 设计报告

匿名竞赛原型 · 协议版本1.0.0 · 阶段9

## 1. 问题与已实现范围

文档或邮件中的恶意指令可能诱导AI Agent调用越权工具。ChainGuard将模型的调用意图、确定性授权、真实工具副作用和可独立核验的审计证据分开，避免将模型输出或网页状态当成执行成功。

当前完整链上场景为R2 mail.send：只投递到本地隔离的SQLite MIME测试邮箱。doc.read与doc.delete具备本地沙箱原语，删除仅限测试文件；R3的合约门槛已测试，但完整C组删除闭环未交付。原始正文、完整参数和随机盐不上链。

技术栈为Python/FastAPI、Solidity0.8.28/Hardhat2.26.3/OpenZeppelin5.4.0、Besu25.10.0四验证节点QBFT、Docker Compose、pytest和React19.1.1/Vite6.3.6。四节点同一宿主，不代表四家组织独立运维。

## 2. 信任边界与威胁模型

攻击者可控制外部文档、邮件内容、Agent提出的工具参数、伪造审批或重放已用授权，并可篡改导出的审计副本。实验攻击者不持有可信批准者、工具或relayer私钥，不控制QBFT法定多数，也不能改写B组的独立检查点。

可信任务服务持有用户授权清单；模型只引用task_id，无权扩大收件人、资源、额度或风险。请求者、业务批准、安全批准、工具签名者和relayer使用不同测试密钥。当前密钥同机管理；生产KMS/HSM、跨机构独立保管与RPC准入尚未验收。

| 分组 | 实际授权差异 | 审计依据 |
| --- | --- | --- |
| A 普通中央 | 账号权限；任务ABAC以shadow记录 | 中央持久日志 |
| B 强化中央 | 强制任务ABAC/RBAC、独立审批签名、工具二次校验 | 签名追加日志与独立检查点 |
| C 联盟链 | 与B共用冻结业务策略，另强制真实reserve及工具独立查链 | 共同链历史、原回执和工具卷 |

三组任务、模型、数据和基础策略一致。A的shadow机制是冻结对照设计；没有削弱B来制造C组优势。

## 3. 权限与数据规范

| 风险 | 任务和资源条件 | 批准与执行门槛 |
| --- | --- | --- |
| R0 公开读取 | PUBLIC_DOCS、明确doc_id、有效任务及配额 | 无逐动作预约；沙箱及签名读取日志 |
| R1 组织读取 | 文档组织匹配、显式任务授权 | 新鲜度不明则拒绝；不降级R0 |
| R2 邮件 | 精确本地收件人、工具/scope/时效/额度 | 请求者签名及不同组织业务/安全审批，最长120秒，真实预约 |
| R3 沙箱删除 | 显式allow_sandbox_delete、max_risk=3、精确测试doc_id | 默认拒绝；再加不同账户人工审批，至少两组织，最长60秒 |

审批者不能与请求者、Agent或工具签名者复用。签名恢复身份后查询当前角色/组织/scope；一个地址只计一个审批位置。策略更新提升policyEpoch，旧授权不能绕过撤销。

ActionIntent按冻结顺序包含14个字段：schemaVersion标记结构版本；actionId为永久唯一动作；taskId绑定任务；requester和agent绑定身份；toolId和resourceScope绑定工具/范围；paramsCommit绑定完整参数；policyId和policyEpoch绑定策略版本；nonce防重放；issuedAt/expiresAt限定有效窗口；risk来自可信风险规则，不能由Agent降级。

ExecutionReceipt按冻结顺序包含7个字段：schemaVersion、actionId、paramsCommit、resultCommit、evidenceIndexCommit、executedAt、outcome。工具对实际结果签名，outcome仅OK/ERROR/REJECTED三类，不把缺回执当成功。

JSON使用snake_case，EIP-712使用原camelCase映射；uint64/uint256使用无符号十进制字符串。参数、结果及证据使用RFC8785 JCS与独立32字节随机盐、域分离keccak256承诺。不得用SHA3-256替代keccak256。

动作域为ChainGuard ExecutionRegistry，回执域为ChainGuard AuditRegistry；version=1。真实chainId=20261026，verifyingContract取实际部署地址。golden vector的31337与中央B的0分域保持，不能搬用签名。

## 4. 状态与恢复

高风险网关主路径：PROPOSED → AWAITING_APPROVAL → RESERVING → RESERVED → EXECUTING → EXECUTION_RECORDED → FINALIZED_*。派发前持久dispatch_started但仍保持RESERVED，真实工具回执确认后才记录执行事实。链状态只有NONE、RESERVED、UNKNOWN及三个FINALIZED终态，不包含EXECUTING。

nonce与actionId一次性消费，失败、过期或撤销都不释放。工具先独立验证预约、当前权限、TaskGrant及承诺，再以永久actionId幂等持久化执行。MIME、配额和签名回执在同一SQLite事务中提交，仅保证该本地邮箱的原子性。

UNKNOWN只查询原日志/回执；有效原回执通过reconcile锚定，不重新派发。待提交队列保存原raw交易/hash/nonce，仅在链健康且原交易确实不存在、nonce未消费时重投同字节。没有原回执则保持未知，终态不可覆盖。

## 5. 合约与最小审计控制台

PolicyRegistry采用双组织EIP-712治理，单方只可紧急暂停；ExecutionRegistry核验同意图审批、当前身份/范围、时效与一次性预约；AuditRegistry核验工具签名及真实结果承诺，支持UNKNOWN对账。Execution/Audit引用不可变，禁止直接角色写入或单方升级替换。

React控制台是独立只读观察者，展示动作历史状态、组织审批、交易hash/区块、工具签名和核验结论。公开投影须先经原工具卷readonly和四节点验证器检查；页面没有approve、reserve、execute、finalize或任意RPC代理。审计容器不挂载工具私有卷，不读取模型Key或签名私钥。

| 只读接口 | 语义 |
| --- | --- |
| GET /health/live、/health/ready | 进程/目录就绪；不宣称链健康 |
| GET /audit-api/v1/network | 四节点chainId/genesis/共同块/代码核验 |
| GET /audit-api/v1/actions | 公开历史列表及A/B/C、状态过滤 |
| GET /audit-api/v1/actions/{entry_id} | 原始字段与承诺的公开投影 |
| GET /audit-api/v1/actions/{entry_id}/verify | 当前真实交易、审批/工具签名复核 |

VERIFIED必须匹配真实预约calldata/事件/nonce、四节点receipt和工具回执。A/B只返回HISTORICAL_ONLY；无预约为NO_RESERVATION；缺回执为PENDING_RECEIPT；查链失败为UNAVAILABLE；篡改为INVALID。历史状态、当前链状态与核验时间分列，健康页面或截图不替代链证据。

部署使用固定Python镜像及已核验Linux wheel缓存、独立前端锁文件。容器非root、只读根、cap-drop ALL、no-new-privileges，回环发布端口，仅挂载公开证据只读卷。浏览器有CSP、TrustedHost与no-store限制；可信本地操作员仍在信任边界内。

## 6. 验证方法、隐私及未完成项

原21份协议清单和8份共享策略清单共25个不同文件，阶段8记录的116份原有源码保持摘要一致。新只读层单独测试；真实协议执行、工具卷副作用与签名、四节点receipt、HTTP及实际浏览器分别验收，不把单元夹具计作真实交易。

报告只使用合成任务、通用组织标签、公开测试地址与相对证据索引，无学校、教师、队员或个人主页信息。PDF作者为空；不附含宿主路径的运行日志作为匿名材料。全仓库及历史日志并非已完成匿名打包，正式提交前还需单独审查。

未完成项：空白OS/全新创世链完整重建、跨机器多机构部署、生产密钥托管/节点认证、完整R3链闭环、其他C工具、完整官方AgentDojo utility和大样本多模型评测。旧区块历史状态可能不可查询；此时只能报告核验不可用。后续扩展必须保持冻结字段、跨组织门槛、工具二验、nonce和预约机制。

依据索引：spec/eip712.json、docs/protocol.md、docs/state-machine.md、docs/phase5-contracts.md、docs/phase6-contracts.md、docs/phase9-contracts.md。实际命令、交易、副作用和失败记录见配套测试报告。